a. Le Password-Based Key Derivation Function moderne prevedono parametri configurabili che aumentano il costo computazionale degli attacchi a forza bruta e di dizionario.

b. In questo comando, il vettore di inizializzazione è solo un valore dummy ma va necessariamente passato per mantenere la coerenza dell'API di OpenSSL

openssl enc -d -aes-128-cbc -in ctext.aes128 -out dtext.aes128 -K ($key) -iv ($iv)

c. Per cifrare un documento Word potrei usare il seguente comando OpenSSL: ✖

openssl pkeyutl -encrypt -in doc_confidenziale.docx -inkey key

d. L'algoritmo di Grover rende deboli gli algoritmi simmetrici contro attacchi a forza bruta su computer quantistici, anche con chiavi di lunghezza elevata, ad es. AES-256 ✖

e. Tre utenti hanno dei certificati RSA da 2048 bit. Confrontando 3 firme sequenziali applicate da tre utenti a un documento, con 3 firme parallele degli stessi utenti applicate allo stesso documento, noterò che quelle sequenziali avranno dimensioni leggermente maggiori.

f. Il teorema cinese del resto mi permette di accelerare le operazioni crittografiche svolte con chiavi RSA, aumentando il rischio di attacchi fisici.

g. L'uso di varianti sicure del CBC-MAC (es. CMAC) può essere consigliato per gli IoT/embedded system.

h. Se un certificato utilizzato per una firma digitale risulta revocato tramite OCSP, allora tutte le firme apposte con quel certificato in passato devono essere considerate non valide. ✖

i. Un timestamp crittografico generato da una TSA affidabile attesta che alcuni dati esistevano prima di una data specifica.

Le risposte corrette sono:
Il teorema cinese del resto mi permette di accelerare le operazioni crittografiche svolte con chiavi RSA, aumentando il rischio di attacchi fisici.

,
L'uso di varianti sicure del CBC-MAC (es. CMAC) può essere consigliato per gli IoT/embedded system., Un timestamp crittografico generato da una TSA affidabile attesta che alcuni dati esistevano prima di una data specifica.

, Le Password-Based Key Derivation Function moderne prevedono parametri configurabili che aumentano il costo computazionale degli attacchi a forza bruta e di dizionario.

Scegli una o più alternative:

- a. Secondo i principi di Cheswick e Bellovin, un firewall è sicuro per sé quando la sua politica di autorizzazione è definita correttamente.
- b. Un application-level filter è sempre consigliato rispetto a un packet filter, perché gestisce gli stati in modo più accurato.
- c. Un circuit-level gateway interrompe il modello client-server tra host interni ed esterni, instaurando connessioni separate per ciascun lato della comunicazione. ✔
- d. IDS identificano con certezza attacchi che si presentano come anomalie statistiche rispetto al comportamento standard degli utenti normali.
- e. Un sistema configurato secondo l'architettura dual homed gateway è poco vulnerabile ai DoS.
- f. Un firewall configurato correttamente lascia passare degli attacchi.
- g. Il Continuous Proactive Monitoring è di solito svolto dal SOC, anche mediante strumenti avanzati per l'analisi delle anomalie. ✔
- h. Un personal firewall consente di proteggere un host in modo molto granulare, poiché ha accesso alle informazioni sui processi. ✔
- i. Un Endpoint (Threat) Detection and Response è uno strumento che, in maniera altamente automatizzata, identifica e riporta situazioni sospette. ✔

Le risposte corrette sono: Il Continuous Proactive Monitoring è di solito svolto dal SOC, anche mediante strumenti avanzati per l'analisi delle anomalie.

,

Un Endpoint (Threat) Detection and Response è uno strumento che, in maniera altamente automatizzata, identifica e riporta situazioni sospette., Un circuit-level gateway interrompe il modello client-server tra host interni ed esterni, instaurando connessioni separate per ciascun lato della comunicazione.

,

Un firewall configurato correttamente lascia passare degli attacchi.

, Un personal firewall consente di proteggere un host in modo molto granulare, poiché ha accesso alle informazioni sui processi.

Scegli una o più alternative:

- a. OWASP Top 10 è uno dei riferimenti per identificare i rischi più importanti dei sistemi web.
- b. Le patch risolvono problemi del software; per come vengono sviluppate, non possono introdurne altri.
- c. Le metriche EPSS indicano la probabilità che una vulnerabilità possa essere sfruttata nel mondo reale.
- d. Ho acquistato un software commerciale e lo uso per alcuni processi della mia azienda. Quando viene scoperta una vulnerabilità in tale software, secondo il NIST IR 8011, se ne dovrebbe occupare il nostro Software Flaw Manager.
- e. Le patch aggregate risolvono il problema di dover applicare la stessa patch a gruppi eterogenei di macchine . ✖
- f. Gli incidenti informatici ad alto impatto economico sono di solito classificati come di elevato rischio. ✔
- g. Secondo quanto indicato dal NIST (SP 800-40), le patch per una CVE con alto CVSS potrebbero dover essere testate su un sottoinsieme di macchine per verificarne la correttezza. ✔
- h. Una vulnerabilità con EPSS alto indica che il suo sfruttamento avrà un impatto elevato.
- i. Nella valutazione del rischio dovrebbero essere considerati almeno il danno massimo, i tempi di recupero della piena funzionalità e la probabilità che si manifesti. ✔

Le risposte corrette sono: Gli incidenti informatici ad alto impatto economico sono di solito classificati come di elevato rischio.

,

OWASP Top 10 è uno dei riferimenti per identificare i rischi più importanti dei sistemi web., Nella valutazione del rischio dovrebbero essere considerati almeno il danno massimo, i tempi di recupero della piena funzionalità e la probabilità che si manifesti.

,

Le metriche EPSS indicano la probabilità che una vulnerabilità possa essere sfruttata nel mondo reale.

,

Secondo quanto indicato dal NIST (SP 800-40), le patch per una CVE con alto CVSS potrebbero dover essere testate su un sottoinsieme di macchine per verificarne la correttezza.

Scegli una o più alternative:

- a. Un prodotto certificato potrebbe consentire di evitare test di sicurezza indipendenti, assumendo che un numero sufficiente di test sia stato effettuato per ottenere la certificazione.
- b. In Italia non esiste un Evaluation Scheme nazionale per la valutazione di prodotti secondo la Common Evaluation Methodology (CEM).
- c. ISO/SAE 21434 impone un'analisi delle minacce e dei rischi per ogni veicolo, ma solo se è presente una connessione ad Internet. ✖
- d. Il Cyber Solidarity Act mira a rafforzare la cooperazione tra gli organismi nazionali nella prevenzione, rilevazione e risposta agli incidenti di sicurezza informatica.
- e. La rivalutazione dei prodotti rende la compliance con i Common Criteria più onerosa da gestire, poiché gli standard meno recenti non richiedevano la rivalutazione del prodotto a seguito di modifiche rilevanti per la sicurezza. ✖
- f. Un Protection Profile definisce i requisiti specifici di una classe omogenea di prodotto, semplificando l'interpretazione dei principi generali dei Common Criteria.
- g. La certificazione ISO 27k1 attesta che l'azienda ha implementato correttamente il Risk Management Framework del NIST.
- h. Il principio del GDPR 'Privacy by default' richiede l'adozione di misure di protezione idonee e che queste siano attivate senza richiesta esplicita dell'utente. ✔
- i. Il NIS2 specifica i controlli di sicurezza tecnici minimi (firewall, IDS, canali sicuri) da implementare in un'infrastruttura critica.

Le risposte corrette sono:
Il principio del GDPR 'Privacy by default' richiede l'adozione di misure di protezione idonee e che queste siano attivate senza richiesta esplicita dell'utente.

,

Un Protection Profile definisce i requisiti specifici di una classe omogenea di prodotto, semplificando l'interpretazione dei principi generali dei Common Criteria. , Un prodotto certificato potrebbe consentire di evitare test di sicurezza indipendenti, assumendo che un numero sufficiente di test sia stato effettuato per ottenere la certificazione.

,

Il Cyber Solidarity Act mira a rafforzare la cooperazione tra gli organismi nazionali nella prevenzione, rilevazione e risposta agli incidenti di sicurezza informatica.

Scegli una o più alternative:

- [x] a. Il protocollo 802.1X definisce il processo per consentire agli utenti l'accesso alla rete dopo una procedura di autenticazione. ✔
- [x] b. Le passkey sono un metodo di autenticazione basato su password che evita la memorizzazione delle password sul server. ✖
- [ ] c. FIDO2 non prevede terze parti fidate durante l'esecuzione della procedura di autenticazione.
- [x] d. DIAMETER è un protocollo che supporta autenticazione, autorizzazione e accounting per l'accesso alla rete. ✔
- [ ] e. EAP è un framework di autenticazione che può essere utilizzato a livello di Data Link, ad esempio nel PPP.
- [x] f. I generatori di OTP non basati sul tempo (es. event-based OTP) non corrono il rischio di desincronizzarsi rispetto al server di verifica. ✖
- [ ] g. Un sistema CRA asimmetrico potrebbe essere implementato richiedendo al claimant di eseguire una firma digitale sui dati della sfida
- [ ] h. Secure Remote Password è un metodo di autenticazione che usa la biometria per sbloccare le credenziali asimmetriche.
- [ ] i. Nel protocollo TLS, i meccanismi di scambio di chiavi effimere non richiedono autenticazione, poiché le chiavi generate sono valide per una sola sessione.

Le risposte corrette sono:
EAP è un framework di autenticazione che può essere utilizzato a livello di Data Link, ad esempio nel PPP.

, Il protocollo 802.1X definisce il processo per consentire agli utenti l'accesso alla rete dopo una procedura di autenticazione.

, DIAMETER è un protocollo che supporta autenticazione, autorizzazione e accounting per l'accesso alla rete.

, FIDO2 non prevede terze parti fidate durante l'esecuzione della procedura di autenticazione.

, Un sistema CRA asimmetrico potrebbe essere implementato richiedendo al claimant di eseguire una firma digitale sui dati della sfida